

Com base nos fundamentos de segurança da informação apresentados nas fontes, estruturei o conteúdo em quatro microtópicos focados em aprendizado ativo e aplicação técnica.

Microtópico 1: A Tríade CID (Confidencialidade, Integridade e Disponibilidade)

Objetivo de aprendizagem: Diferenciar os três pilares fundamentais da segurança da informação em cenários de incidentes reais.

- **Exercício 1: Associação de Conceitos**

- **Tipo:** Associação
- **Enunciado:** Associe o incidente ao pilar da segurança que foi violado:
 1. Um hacker visualiza dados médicos sigilosos sem autorização.
 2. Um vírus altera os valores de uma planilha financeira de uma empresa.
 3. Um ataque de negação de serviço deixa o site de um banco fora do ar.
- **Resposta correta:** 1-Confidencialidade; 2-Integridade; 3-Disponibilidade.
- **Feedback:** A Confidencialidade garante que apenas pessoas autorizadas vejam o dado; a Integridade garante que o dado não foi alterado; a Disponibilidade garante que o sistema esteja acessível quando necessário.

- **Exercício 2: Diagnóstico de Incidente (Estudo de Caso Fleury)**

- **Tipo:** Múltipla escolha contextualizada
- **Enunciado:** No ataque de Ransomware ao Grupo Fleury, os sistemas de agendamento e entrega de resultados ficaram paralisados por vários dias. Qual pilar foi o mais severamente impactado inicialmente? A) Integridade B) Confidencialidade C) Disponibilidade
- **Resposta correta:** C
- **Feedback:** Embora o ransomware possa afetar outros pilares, a paralisação operacional total é uma violação direta da Disponibilidade, impedindo o acesso oportuno às informações.

- **Exercício 3: Reconhecimento Técnico**

- **Tipo:** Reconhecimento técnico
- **Enunciado:** Um administrador de banco de dados percebeu que um registro de log foi apagado para esconder uma transação fraudulenta. Qual propriedade da segurança foi violada?
- **Resposta correta:** Integridade.
- **Feedback:** A exclusão ou modificação não autorizada de registros fere a integridade, pois a informação original foi destruída ou alterada de forma indevida.

Microtópico 2: Propriedades de Segurança e IAM

Objetivo de aprendizagem: Identificar as etapas de Identificação, Autenticação e Autorização dentro de um sistema de Gestão de Identidade e Acesso (IAM).

- **Exercício 1: Fluxo de Acesso**
 - **Tipo:** Classificação ou ordenação
 - **Enunciado:** Ordene as etapas de acesso de um usuário ao sistema seguindo a lógica do IAM: () O sistema verifica se o usuário tem permissão para imprimir o arquivo (Autorização). () O usuário informa seu nome de login (Identificação). () O usuário insere sua senha e biometria para validar quem diz ser (Autenticação).
 - **Resposta correta:** 3, 1, 2.
 - **Feedback:** O fluxo correto começa pela Identificação (quem você é), segue pela Autenticação (prova de quem você é) e termina na Autorização (o que você pode fazer).
- **Exercício 2: Decisão Técnica - Fatores de Autenticação**
 - **Tipo:** Decisão técnica
 - **Enunciado:** Você precisa aumentar a segurança de um aplicativo bancário. Qual combinação abaixo representa uma Autenticação de Múltiplos Fatores (MFA) eficaz segundo as fontes? A) Senha (saber) e PIN (saber). B) Senha (saber) e Token no celular (ter). C) Cartão de acesso (ter) e Chave da sala (ter).
 - **Resposta correta:** B
 - **Feedback:** A segurança aumenta quando usamos fatores independentes: algo que você sabe (senha) e algo que você tem (token/celular).
- **Exercício 3: Responsabilização (Accountability)**
 - **Tipo:** Simulação conceitual
 - **Enunciado:** Um sistema registra que o usuário "joao.silva" realizou uma transferência às 14:32 do IP 192.168.1.1. Se o sistema permitir que o João apague esse registro, qual propriedade de segurança é perdida?
 - **Resposta correta:** Não repúdio (ou Responsabilização).
 - **Feedback:** O Não Repúdio garante que uma entidade não possa negar a autoria de uma ação. Se os logs puderem ser apagados, a Accountability (responsabilização) é comprometida.

Microtópico 3: Ameaças, Vulnerabilidades e Riscos

Objetivo de aprendizagem: Aplicar o cálculo de risco baseando-se na exploração de vulnerabilidades por ameaças.

- **Exercício 1: Associação da Cadeia de Risco**

- **Tipo:** Associação
- **Enunciado:** Associe os termos ao cenário de um e-commerce:
 1. Servidor sem backup e com software desatualizado.
 2. Um grupo hacker buscando dados de cartões de crédito.
 3. A possibilidade real de perda total dos dados dos clientes.
- **Resposta correta:** 1-Vulnerabilidade; 2-Ameaça; 3-Risco.
- **Feedback:** A ameaça é o agente externo, a vulnerabilidade é a fraqueza interna (falta de backup) e o risco é o potencial de dano resultante dessa combinação.

- **Exercício 2: Matriz de Risco**

- **Tipo:** Decisão técnica
- **Enunciado:** Um servidor de vendas possui uma vulnerabilidade com **Probabilidade Média** de ser explorada, mas o **Impacto** caso aconteça é **Muito Alto** (paralisação total das vendas). De acordo com a matriz de risco das fontes, como esse risco deve ser classificado?
- **Resposta correta:** Risco Alto.
- **Feedback:** Na matriz de risco, a combinação de impacto muito alto com probabilidade média resulta em um nível de risco Alto (vermelho/laranja), exigindo prioridade na correção.

- **Exercício 3: Tipos de Ameaças**

- **Tipo:** Reconhecimento técnico
- **Enunciado:** Uma enchente que atinge o data center e desliga os servidores é classificada como qual tipo de ameaça? A) Ameaça Humana Interna B) Ameaça Técnica C) Ameaça Natural
- **Resposta correta:** C
- **Feedback:** Ameaças naturais envolvem eventos como incêndios, enchentes e tempestades que causam indisponibilidade.

Microtópico 4: Malware e Vetores de Infecção

Objetivo de aprendizagem: Diferenciar tipos de softwares maliciosos e seus comportamentos em sistemas corporativos.

- **Exercício 1: Identificação de Comportamento**

- **Tipo:** Associação
- **Enunciado:** Associe o comportamento ao tipo de malware:
 1. Infecta arquivos e precisa ser executado pelo usuário para se espalhar.
 2. Se propaga automaticamente explorando vulnerabilidades de rede.
 3. Disfarça-se como um programa legítimo para enganar o usuário.
- **Resposta correta:** 1-Vírus; 2-Worm; 3-Trojan.

- **Feedback:** O vírus depende do usuário; o Worm é independente e se espalha pela rede; o Trojan (Cavalo de Troia) foca em enganar a vítima.
- **Exercício 2: Completar (Ransomware)**
 - **Tipo:** Completar ou corrigir
 - **Enunciado:** O _____ é um tipo de malware que realiza a _____ dos arquivos do usuário e exige o pagamento de um resgate para devolvê-los.
 - **Resposta correta:** Ransomware / criptografia.
 - **Feedback:** O Ransomware bloqueia o acesso aos dados via criptografia, causando impacto financeiro e operacional imediato.
- **Exercício 3: Reconhecimento de Ameaça Moderna**
 - **Tipo:** Múltipla escolha contextualizada
 - **Enunciado:** Um atacante infectou milhares de dispositivos para realizar um ataque de negação de serviço (DDoS) contra um site de governo. Qual o nome dado a essa rede de computadores zumbis controlados remotamente? A) Spyware B) Botnet C) Keylogger
 - **Resposta correta:** B
 - **Feedback:** Uma Botnet é uma rede de bots controlada por um servidor de comando (C&C) para realizar ataques em larga escala, como o DDoS.

Com certeza. Vamos focar nos **Conceitos Básicos**, que formam o alicerce da Segurança da Informação conforme apresentado nas fontes.

Microtópico 1: Definição e Escopo da Segurança

Objetivo de aprendizagem: Compreender que a Segurança da Informação é composta por tecnologia, pessoas e processos, e não apenas TI.

- **Exercício 1: Reconhecimento Técnico**
 - **Tipo:** Múltipla escolha contextualizada
 - **Enunciado:** Uma empresa investe nos melhores firewalls do mercado, mas não treina seus funcionários sobre senhas seguras. De acordo com as fontes, por que essa estratégia é incompleta?, A) Porque a segurança depende apenas de software atualizado. B) Porque a segurança da informação envolve o equilíbrio entre Tecnologia, Pessoas e Processos. C) Porque processos são irrelevantes se a tecnologia for de ponta.
 - **Resposta correta:** B
 - **Feedback:** A segurança não é apenas tecnologia; ela depende fundamentalmente de pessoas treinadas e processos bem definidos.,
- **Exercício 2: Associação de Pilares**
 - **Tipo:** Associação

- **Enunciado:** Relacione os elementos do escopo da segurança aos seus exemplos práticos:
 1. Tecnologia
 2. Pessoas
 3. Processos () Treinamento de conscientização e cultura organizacional. () Configuração de servidores e softwares de proteção. () Normas de uso de ativos e fluxos de trabalho.
 - **Resposta correta:** 2, 1, 3.
 - **Feedback:** Tecnologia são as ferramentas; Pessoas são o fator humano; Processos são as regras que regem como ambos interagem.
-

Microtópico 2: A Tríade CID (Confidencialidade, Integridade e Disponibilidade)

Objetivo de aprendizagem: Identificar os três princípios fundamentais da ISO 27000 que estruturam a proteção da informação.,

● Exercício 1: Completar lacunas

- **Tipo:** Completar ou corrigir
- **Enunciado:** Preencha com o pilar correto: A _____ garante que a informação não seja vista por pessoas não autorizadas. A _____ assegura que o dado não foi modificado indevidamente. A _____ garante que o sistema esteja acessível quando necessário.
- **Resposta correta:** Confidencialidade / Integridade / Disponibilidade.
- **Feedback:** Estes três pilares formam a base da ISO 27000 para a preservação da informação.,

● Exercício 2: Diagnóstico de Impacto

- **Tipo:** Simulação conceitual
- **Enunciado:** Um aluno não consegue acessar o portal acadêmico para ver suas notas no dia do fechamento do semestre porque o servidor travou. Qual pilar foi violado?,
- **Resposta correta:** Disponibilidade.
- **Feedback:** A Disponibilidade foca no acesso e uso oportuno e confiável das informações quando necessário.

● Exercício 3: Reconhecimento de Violação

- **Tipo:** Reconhecimento técnico
- **Enunciado:** Um invasor altera o saldo bancário de um cliente em uma base de dados, mas não retira o dinheiro. Qual pilar foi o foco principal deste ataque?,
- **Resposta correta:** Integridade.
- **Feedback:** A Integridade visa assegurar que a informação não seja modificada ou destruída de forma não autorizada.

Microtópico 3: Ativos de Informação

Objetivo de aprendizagem: Definir o que é um ativo e reconhecer que a informação tem valor independente do seu formato.,

- **Exercício 1: Classificação de Ativos**

- **Tipo:** Classificação ou ordenação
- **Enunciado:** Classifique os itens abaixo como "Ativo" ou "Não Ativo" de informação para uma empresa:
 1. Banco de dados de clientes. ()
 2. Mobiliário de escritório comum sem dados. ()
 3. Código-fonte de um aplicativo próprio. ()
 4. Prontuário médico em papel. ()
- **Resposta correta:** 1-Ativo; 2-Não Ativo; 3-Ativo; 4-Ativo.
- **Feedback:** Um ativo é qualquer informação que tenha valor para a organização, podendo estar em formato digital ou físico.

- **Exercício 2: Decisão Técnica - Identificação de Valor**

- **Tipo:** Decisão técnica
- **Enunciado:** Ao iniciar uma estratégia de segurança, qual deve ser o primeiro passo segundo as fontes? A) Instalar o antivírus mais caro disponível. B) Identificar os ativos de informação e analisar como proteger a tríade CID para cada um. C) Demitir funcionários que não conhecem TI.
- **Resposta correta:** B
- **Feedback:** Toda estratégia de segurança começa pela identificação dos ativos e pela análise de como proteger sua confidencialidade, integridade e disponibilidade.

Deseja prosseguir para os exercícios de Gestão de Identidade e Acesso (IAM)?

Com base nas propriedades de segurança que expandem a tríade CID, estruturei os exercícios focados em **Autenticidade, Privacidade, Não Repúdio e Responsabilização**.

Microtópico 1: Autenticidade – Verificação de Identidade

Objetivo de aprendizagem: Identificar mecanismos que garantam a veracidade da identidade de uma entidade antes do acesso.

- **Exercício 1: Reconhecimento Técnico**

- **Tipo:** Múltipla escolha contextualizada

- **Enunciado:** Um usuário tenta acessar sua conta bancária. O sistema solicita o login/senha e, em seguida, um código temporário enviado ao celular (token). Qual propriedade o sistema está tentando alcançar com este segundo fator? A) Disponibilidade B) Autenticidade C) Privacidade
 - **Resposta correta:** B
 - **Feedback:** A autenticidade assegura que a entidade é realmente quem afirma ser, utilizando fatores como "algo que você sabe" e "algo que você tem".
 - **Exercício 2: Associação pilar-apoio**
 - **Tipo:** Associação
 - **Enunciado:** A autenticidade não atua sozinha. Associe como ela apoia os pilares da tríade CID:
 1. Confidencialidade
 2. Integridade () Impede que usuários falsos visualizem dados restritos.
() Impede que entidades falsas modifiquem informações do sistema.
 - **Resposta correta:** 1, 2.
 - **Feedback:** Ao validar a identidade, a autenticidade garante que apenas as pessoas certas vejam (confidencialidade) ou alterem (integridade) os dados.
 - **Exercício 3: Decisão Técnica**
 - **Tipo:** Decisão técnica
 - **Enunciado:** Um desenvolvedor quer implementar um login apenas com senha simples. De acordo com as fontes, qual a recomendação para tornar a autenticidade mais robusta? A) Aumentar o tempo de expiração da sessão. B) Utilizar múltiplos fatores independentes (MFA), como biometria ou tokens físicos. C) Permitir que o usuário escolha qualquer nome de login.
 - **Resposta correta:** B
 - **Feedback:** Quanto mais fatores independentes forem utilizados (saber, ter ou ser), maior será a segurança da autenticidade.
-

Microtópico 2: Privacidade – Proteção de Dados Sensíveis

Objetivo de aprendizagem: Diferenciar o conceito de privacidade e sua aplicação na proteção de dados pessoais.

- **Exercício 1: Simulação Conceitual (Cenário Hospitalar)**
 - **Tipo:** Classificação ou ordenação
 - **Enunciado:** Em um hospital, médicos podem visualizar prontuários, mas recepcionistas possuem acesso bloqueado a esses dados. Qual propriedade está sendo preservada ao aplicar essas restrições?
 - **Resposta correta:** Privacidade.
 - **Feedback:** A privacidade garante que dados sensíveis sejam acessados apenas por entidades autorizadas e para finalidades legítimas.

- **Exercício 2: Associação de Conceitos**

- **Tipo:** Associação
- **Enunciado:** A privacidade é considerada uma aplicação direta de qual pilar da tríade CID?
- **Resposta correta:** Confidencialidade.
- **Feedback:** As fontes definem a privacidade como a confidencialidade aplicada especificamente ao contexto de dados pessoais.

- **Exercício 3: Reconhecimento de Erro**

- **Tipo:** Reconhecimento técnico
 - **Enunciado:** Se todos os funcionários de uma empresa puderem ver os saldos das contas de todos os clientes sem necessidade funcional, qual propriedade foi violada?
 - **Resposta correta:** Privacidade.
 - **Feedback:** O acesso sem finalidade legítima ou autorização específica rompe a garantia de privacidade do dado pessoal.
-

Microtópico 3: Não Repúdio e Responsabilização (Accountability)

Objetivo de aprendizagem: Distinguir a capacidade de provar autoria (não repúdio) do registro detalhado de ações (accountability).

- **Exercício 1: Completar ou Corrigir**

- **Tipo:** Completar ou corrigir
- **Enunciado:** O _____ permite provar que uma entidade realizou uma ação, impedindo que ela negue a autoria. Já a _____ identifica de forma inequívoca quem, quando, onde e como uma ação foi feita.
- **Resposta correta:** Não Repúdio / Responsabilização (ou Accountability).
- **Feedback:** O não repúdio foca na prova de autoria; a accountability foca no rastreamento e auditoria completa da ação.

- **Exercício 2: Simulação de Pronta Resposta**

- **Tipo:** Reconhecimento técnico
- **Enunciado:** Um usuário assina um contrato digital usando sua **chave privada**. Dias depois, ele afirma que não foi ele quem assinou. Qual mecanismo técnico impede essa negação? A) Disponibilidade B) Não repúdio C) Backup
- **Resposta correta:** B
- **Feedback:** A assinatura digital vinculada a uma chave privada garante o não repúdio, pois apenas o dono da chave poderia ter gerado a assinatura.

- **Exercício 3: Auditoria Técnica**

- **Tipo:** Múltipla escolha contextualizada

- **Enunciado:** Um administrador analisa os logs e vê: "Usuário: joao.silva | Ação: Transferência | Data: 02/03/2026 14:32 | IP: 192.168.1.1". Para que esses registros gerem **Accountability**, o que é estritamente necessário no sistema? A) Que o servidor tenha alta disponibilidade. B) Que os logs possam ser editados pelos usuários. C) Que a identificação do usuário seja única e os registros sejam confiáveis.
 - **Resposta correta:** C
 - **Feedback:** A responsabilização depende diretamente de identificação única, registros confiáveis e trilhas de auditoria íntegras.
-

Deseja prosseguir para os exercícios de Gestão de Identidade e Controle de Acesso (IAM)?

Com base nos fundamentos de **Gestão de Identidade e Controle de Acesso (IAM)** apresentados nas fontes, aqui estão os exercícios estruturados para este tópico:

Microtópico 1: Fundamentos e Dimensões do IAM

Objetivo de aprendizagem: Diferenciar as duas dimensões principais do IAM (Identidade vs. Acesso) e seus processos básicos.

- **Exercício 1: Associação de Dimensões**

- **Tipo:** Associação
- **Enunciado:** Associe a dimensão do IAM à pergunta fundamental que ela responde:
 1. Gestão de Identidade
 2. Gestão de Acesso () "O que este usuário pode fazer dentro do sistema?" () "Quem é este usuário de forma única?"
- **Resposta correta:** 2, 1.
- **Feedback:** A Gestão de Identidade foca na individualização do sujeito, enquanto a Gestão de Acesso define suas permissões e privilégios.

- **Exercício 2: Completar o Ciclo IAM**

- **Tipo:** Completar ou corrigir
 - **Enunciado:** O IAM é um conjunto de processos para: identificar usuários, _____ identidades, _____ acessos e registrar atividades.
 - **Resposta correta:** autenticar / autorizar.
 - **Feedback:** O fluxo completo envolve garantir que o usuário é quem diz ser (autenticar) e definir o que ele pode acessar (autorizar).
-

Microtópico 2: Autenticação e Múltiplos Fatores (MFA)

Objetivo de aprendizagem: Identificar e combinar corretamente os três fatores de autenticação para aumentar a segurança.

- **Exercício 1: Classificação de Fatores**

- **Tipo:** Associação
- **Enunciado:** Classifique o método de autenticação conforme o seu tipo:
 1. Algo que você sabe
 2. Algo que você tem
 3. Algo que você é () Impressão digital ou reconhecimento facial. () Senha numérica (PIN) ou frase secreta. () Token físico, smart card ou celular.
- **Resposta correta:** 3, 1, 2.
- **Feedback:** A segurança é maior quando utilizamos fatores independentes de categorias diferentes.

- **Exercício 2: Decisão Técnica (Internet Banking)**

- **Tipo:** Decisão técnica
- **Enunciado:** No cenário de um Internet Banking que exige senha e um código enviado ao celular, qual o impacto direto de remover a exigência do código no celular? A) Melhora a integridade dos dados. B) Reduz a robustez da autenticidade, facilitando acessos indevidos. C) Aumenta a privacidade do usuário.
- **Resposta correta:** B.
- **Feedback:** Remover o segundo fator (algo que você tem) fragiliza a verificação da identidade (autenticidade).

Microtópico 3: Autorização e o Modelo Sujeito-Objeto

Objetivo de aprendizagem: Aplicar o modelo de autorização para definir permissões sobre recursos do sistema.

- **Exercício 1: Reconhecimento do Modelo**

- **Tipo:** Associação
- **Enunciado:** No modelo de autorização, identifique os componentes:
 1. Sujeito
 2. Objeto
 3. Permissão () Um arquivo de banco de dados ou uma API. () Ação de Criar, Ler, Atualizar ou Deletar (CRUD). () O usuário logado que tenta realizar a ação.
- **Resposta correta:** 2, 3, 1.
- **Feedback:** O sistema decide se um Sujeito pode realizar uma Permissão específica sobre um determinado Objeto.

- **Exercício 2: Simulação de Acesso**

- **Tipo:** Múltipla escolha contextualizada
 - **Enunciado:** Em um sistema hospitalar, médicos podem ler e editar prontuários (Update), mas recepcionistas só podem visualizar a agenda (Read). Se uma recepcionista tentar alterar um prontuário, qual processo do IAM deve bloqueá-la? A) Identificação B) Autenticação C) Autorização
 - **Resposta correta:** C.
 - **Feedback:** A autorização determina quais ações um usuário já autenticado pode executar sobre recursos específicos.
-

Microtópico 4: Auditoria e Logging (Accountability)

Objetivo de aprendizagem: Reconhecer os requisitos essenciais para garantir a responsabilização (Accountability) em um sistema.

- **Exercício 1: Anatomia de uma Trilha de Auditoria**

- **Tipo:** Reconhecimento técnico
- **Enunciado:** Para que uma trilha de auditoria seja considerada eficaz e permita a **Responsabilização**, ela deve responder obrigatoriamente a quatro perguntas. Quais são elas?
- **Resposta correta:** Quem, Fez o quê, Quando e De onde.
- **Feedback:** Sem essas quatro informações, é impossível identificar de forma inequívoca o responsável por uma ação anômala.

- **Exercício 2: Diagnóstico de Risco em Logs**

- **Tipo:** Decisão técnica
 - **Enunciado:** Durante uma auditoria, percebe-se que os administradores do sistema possuem permissão para apagar os logs de suas próprias ações. Qual o principal risco dessa configuração? A) Perda de disponibilidade do sistema. B) Impossibilidade de garantir a Accountability (Responsabilização), pois as evidências podem ser destruídas. C) Aumento no consumo de armazenamento do servidor.
 - **Resposta correta:** B.
 - **Feedback:** A accountability depende de registros confiáveis e íntegros. Se o usuário puder apagar seus rastros, a responsabilização é perdida.
-

Deseja prosseguir para os exercícios de Ameaças, Vulnerabilidades e Riscos?